RAPPORT DE CYBERSECURITE

CHAPITRE 2 : HARDENEING & VULNERABILITY MANAGEMENT

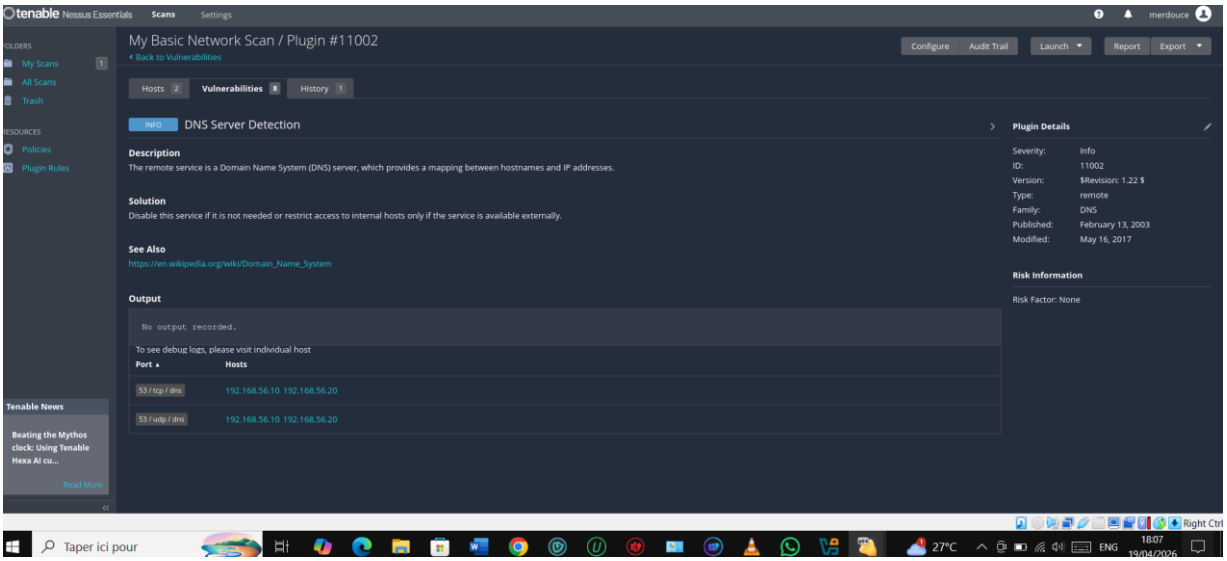
TP 2.2 : analyse et correction des vulnérabilités (linux and Windows)

I. Analyses des vulnérabilités obtenues dans le TP2.1

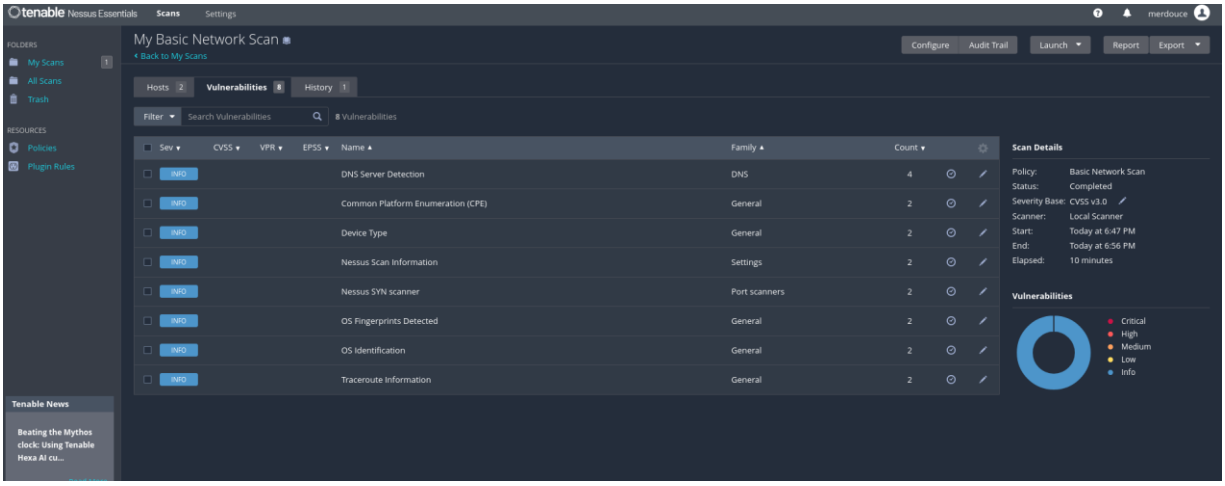
Sur la machine Windows nous avons identifier plusieurs vulnérabilités parmi lesquels :

a) Première vulnérabilité de Windows

La vulnérabilité de niveau élevé, également connue sous le nom d'attaque **Sweet32**, détectée sur ton hôte Windows. Cette vulnérabilité est identifiable par la **CVE-20162183** suivante :



Interprétation de la vulnérabilité



i. Le Problème (La Cause)

Le serveur autorise l'utilisation d'algorithmes de chiffrement par blocs de **64 bits**, plus précisément le **3DES** (Triple DES). Ces algorithmes anciens possèdent une limite mathématique : après un grand nombre de blocs chiffrés avec la même clé, des collisions apparaissent inévitablement.

ii. Le Risque (L'Impact)

- Perte de confidentialité : Un attaquant peut récupérer des données sensibles en clair (comme des **cookies de session**, des identifiants ou des jetons d'authentification) qui circulent dans le tunnel chiffré.
- **Sévérité :** Classée comme Élevée (High) avec un score CVSS de 7.5, car elle compromet la base même de la sécurité des échanges.

iii. L'Exploitation par un attaquant

L'attaque se déroule généralement selon ce scénario :

- Interception (Man-in-the-Middle) : L'attaquant se place entre la victime et le serveur,
- Collecte de données : Il force ou attend une session très longue (plusieurs Go de données transférées) pour capturer suffisamment de trafic,
- Attaque par "Anniversaire" (Birthday Attack) : En analysant les collisions de blocs, il peut mathématiquement déduire une partie du texte en clair sans posséder la clé de chiffrement.

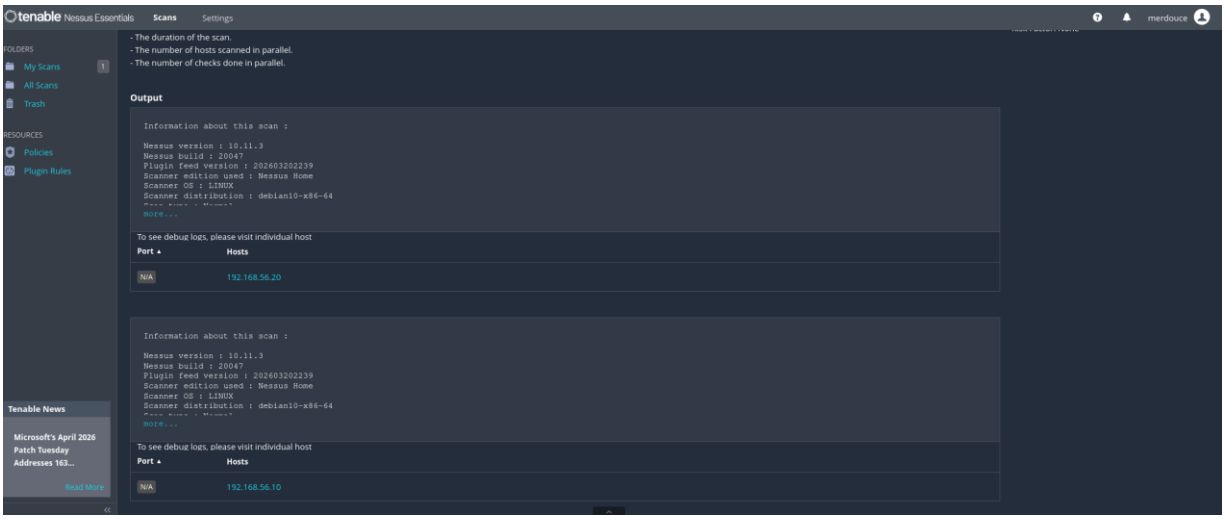
b) La deuxième vulnérabilité de Windows

Cette seconde vulnérabilité détectée sur le port **3389 (RDP)** de ta machine Windows. Cette vulnérabilité est identifiable par la **CVE-2016-2183** suivante :

Interprétation de la vulnérabilité

i. Le Problème (La Cause)

Le certificat SSL/TLS utilisé par le service de Bureau à Distance (RDP) n'est pas considéré comme fiable par Nessus. Cela arrive généralement parce que :



Le certificat est auto-signé (généré par la machine elle-même plutôt que par une autorité de certification reconnue).

- La chaîne de confiance est rompue (autorité parente inconnue).
- Le certificat a expiré ou n'est pas encore valide.

ii. Le Risque (L'Impact)

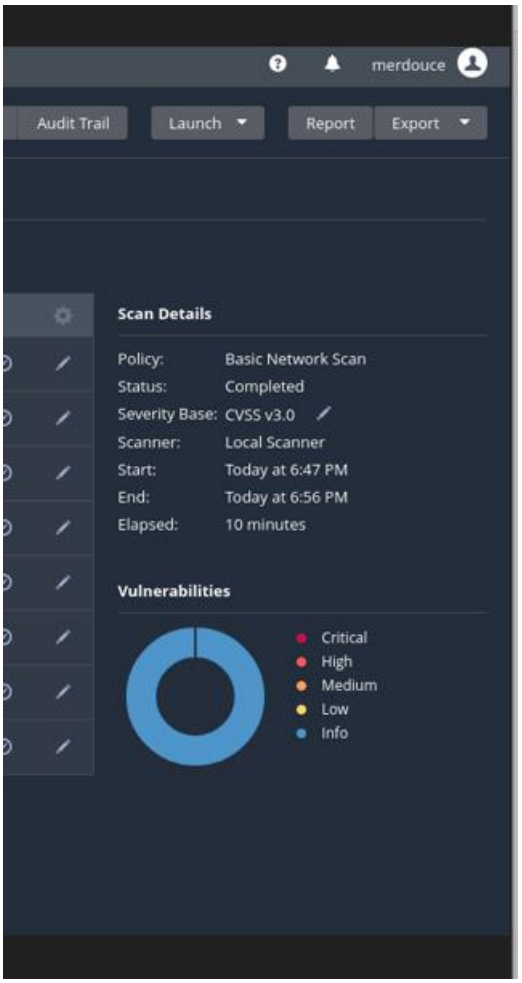
- Attaque Man-in-the-Middle (MITM) **:** Comme l'identité du serveur n'est pas vérifiée par un tiers de confiance, un attaquant peut intercepter la connexion.
- Usurpation d'identité : Un utilisateur peut se connecter à une fausse machine pensant être sur le serveur légitime, exposant ainsi ses identifiants Windows (Login/Mot de passe).
- Sévérité : Moyenne (Medium) : Bien que cela ne permette pas une intrusion directe comme une faille critique, c'est une porte ouverte pour le vol d'identifiants sur le réseau local.

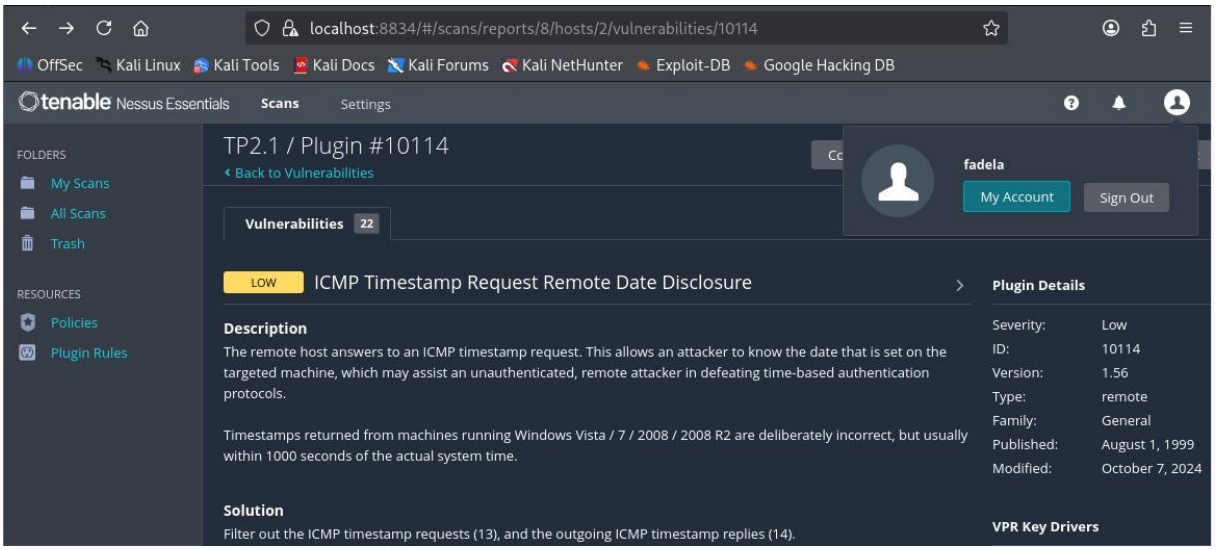
iii. L'Exploitation par un attaquant

- Détournement de flux : L'attaquant utilise une technique comme l'empoisonnement ARP (ARP Spoofing) pour rediriger le trafic RDP vers sa propre machine.
- Présentation d'un faux certificat : Puisque la machine d'origine utilise déjà un certificat non approuvé, l'utilisateur a l'habitude de cliquer sur "Ignorer l'avertissement".
- Capture des données : L'attaquant établit la connexion avec l'utilisateur, récupère les identifiants de session en clair, puis les relaie au vrai serveur pour ne pas éveiller de soupçons.

c) Vulnérabilité Ubuntu

Cette vulnérabilité **CVE-1999-0524** (Plugin #10114) identifiée sur le système Ubuntu. Elle est de degré faible mais reste tout de même intéressante.


merdouce
Audit Trail
Launch
Report
Export
Scan Details
Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 6:47 PM
End: Today at 6:56 PM
Elapsed: 10 minutes
Vulnerabilities
Critical
High
Medium
Low
Info



Interprétation de la vulnérabilité

i. Le Problème (La Cause)

La machine distante répond aux requêtes ICMP Timestamp. Il s'agit d'une fonctionnalité du protocole ICMP (utilisé par ping) qui permet à un hôte de demander l'heure système d'une autre machine. Par d éfaut, de nombreux systèmes d'exploitation répondent à ces requêtes sans filtrage.

ii. Le Risque (L'Impact)

- Divulgation d'informations (Information Disclosure) : Bien que classée comme Faible (Low) avec un score CVSS de 2.1, cette faille permet à un attaquant de connaître l'heure exacte réglée sur le serveur.
- Reconnaissance : Connaître l'heure système peut aider un attaquant à synchroniser une attaque temporelle ou à contourner des protocoles d'authentification basés sur le temps (comme certains jetons OTP ou Kerberos) si l'écart est important.
- CWE-200 : Cette vulnérabilité appartient à la catégorie "Exposition d'informations sensibles à une personne non autorisée".

iii. L'Exploitation par un attaquant

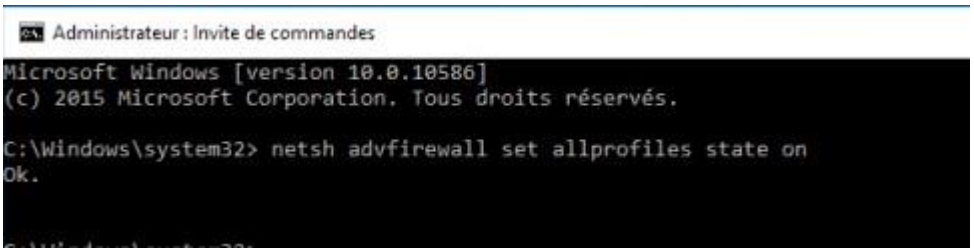
L'exploitation est passive et très simple :

- Envoi de requête : L'attaquant envoie un paquet ICMP de type 13 (Timestamp Request) vers la cible.
- Réception : Le serveur répond avec un paquet ICMP de type 14 contenant son horloge interne.
- Analyse : L'attaquant utilise cette donnée pour affiner sa phase de reconnaissance (fingerprinting) sans alerter les systèmes de détection d'intrusion classiques, car le trafic ICMP est souvent autorisé.

II. Correction linux et Windows

Nous allons à présent réactiver le pare-feu sur la machine Windows pour éliminer certaines vulnérabilités.

Activation du pare-feu Windows



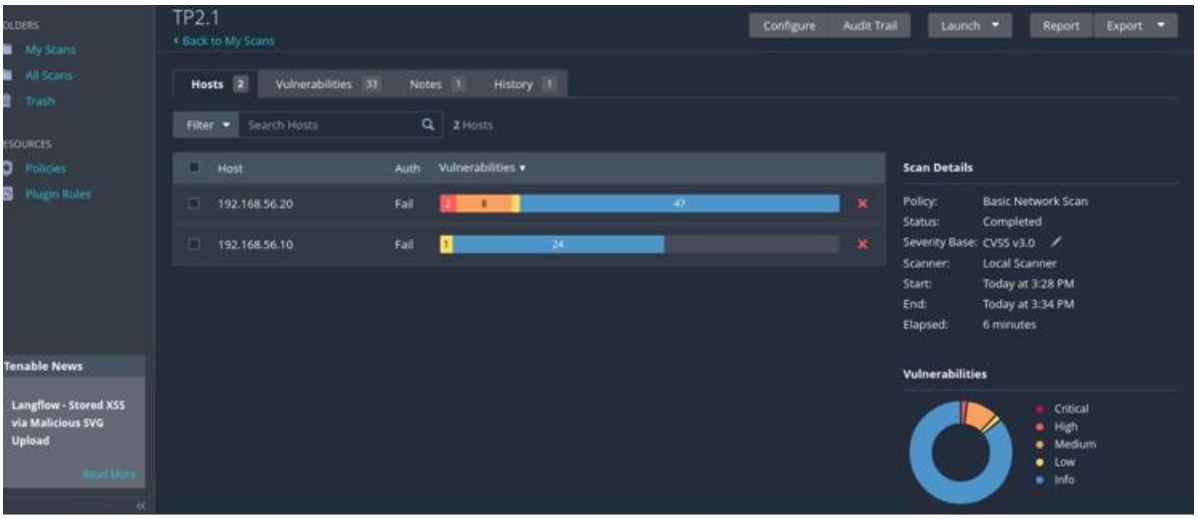
Nous allons à présent réactiver le pare-feu sur la machine Ubuntu pour éliminer certaines vulnérabilités.

Activation du pare-feu Ubuntu

Aucun service n’a été jugé inutiles donc il n’a pas été nécessaires de les désactiver.

III. Re-scan Nessus

Nous avons relancé le scan pour identifier les vulnérabilités qui ont disparu. Nous rappelons que le résultat obtenu au TP2.1 est le suivant :



Apres avoir effectuer a nouveau le scan nous avons obtenu le résultat après configuration des pares-feux est le suivant :

Etude comparative des deux scans

i. Évolution des vulnérabilités sur l'hôte Windows (192.168.56.20)

Avant l'activation du pare-feu, cette machine était la plus exposée.

- **Constat :** Les 2 vulnérabilités critiques sont toujours présentes. Cela prouve que le pare-feu n'empêche pas l'exploitation de failles logicielles sur des ports qui restent ouverts (comme le RDP ou SMB).
- **Changement :** On observe la disparition d'une vulnérabilité de niveau Moyen (passant de 8 à 7). Le pare-feu a probablement bloqué un port secondaire ou un service de découverte que Nessus utilisait pour identifier une configuration risquée.

- **Nettoyage mineur :** Une vulnérabilité de type "Info" a également disparu, indiquant que le système est désormais plus "silencieux" sur le réseau.

ii. Évolution des vulnérabilités sur l'hôte Ubuntu (192.168.56.10)

Pour la machine Ubuntu, l'impact est encore plus subtil.

- **Constat :** La vulnérabilité **Critique** unique persiste. Comme pour Windows, le parefeu protège les entrées non autorisées, mais ne "répare" pas le service vulnérable luimême.

- **Changement :** Le nombre de résultats "Info" est passé de 24 à 23. L'activation du pare-feu a filtré une réponse protocolaire (peut-être le fameux ICMP Timestamp) qui n'est plus accessible depuis l'extérieur.

Nous constatons que le score de vulnérabilité global reste très élevé. Malgré la configuration des pares-feux, le nombre total de vulnérabilités critiques est resté inchangé : 3 au total dont 2 sur Windows, 1 sur Ubuntu. Nous pouvons donc conclure que l'activation du pare-feu n'a eu aucun impact sur le score de risque maximal de ces machines. Il n’est dont pas une mesure de sécurité efficace.